HU.151 – AUTENTICAR COM GOV.BR

PROJETO: Viabiliza — Sistema de Licenciamento Eletrônico

HISTÓRICO DE REVISÃO			
DATA	**RESUMO DAS ALTERAÇÕES**	**VERSÃO**	**Responsável**
16/10/2026	Revisão pelo código-fonte vigente	2.0	Sudoeste Informática

VISÃO GERAL

Catálogo Viabiliza: HU-151. O cidadão entra no portal pelo Login Único. A identidade é o CPF do sub. Conta existente é vinculada; conta nova é criada de verdade. Com o interruptor desligado ou sem credenciais, as rotas recusam e avisam, sem simular sessão Regras evidenciadas no código: (1) RN-001: sem interruptor e sem as duas credenciais, não há redirect ao provedor (GovBr::loginAvailable, GovBrLoginController::unavailable). (2) RN-002: o vínculo de conta existente é só pelo CPF do sub (GovBrAuthService::authenticate). (3) RN-003: o nível mínimo efetivo está em security.govbr.minimum_level, não em outra chave (ensureMinimumLevel). (4) RN-004: conta inativa não autentica e gera o evento inativada (ensureActive). (5) RN-005: primeiro acesso exige e-mail verificado no provedor, papel de cidadão e email_verified_at local (register). (6) RN-006: e-mail do GOV.BR já usado por outro CPF impede a criação (register). (7) RN-007: protocolo com state inválido ou sem conclusão no provedor não cria sessão (GovBrProvider::user, GovBrLoginController::callback). (8) RN-008: sucesso e bloqueio por nível ficam auditados (login-govbr, cadastro-govbr, logBlocked). O access_logs de sucesso continua o listener genérico de Login (evento login, canal portal). Este controller não preenche auth_origin. Fluxo evidenciado: 1. GovBr::loginAvailable() exige features.govbr_login ligado (Settings::enabled('govbr_login')) e integrations.govbr.client_id e integrations.govbr.client_secret preenchidos. O padrão do interruptor em config/viabiliza.php é desligado. Se indisponível, redirect e callback voltam a login com o erro: "O login com GOV.BR está indisponível no momento. Entre com e-mail e senha." 2. Disponibilidade ok: Socialite::driver('govbr')->redirect(). O provider GovBrProvider usa PKCE ($usesPKCE = true), escopos openid, email, profile, govbr_confiabilidades e govbr_confiabilidades_idtoken, grava nonce na sessão e pede autorização em {base_url}/authorize. A URL base vem de integrations.govbr.base_url 3. No callback, error preenchido na query volta com: "A autorização no GOV.BR não foi concluída. Você pode tentar novamente ou entrar com e-mail e senha." InvalidStateException volta com sessão de autenticação expirada 4. GovBrProvider::user exige id_token e GovBrIdTokenValidator::validate com client id, URL base e o nonce da sessão. O token é pedido com Authorization Basic; client id e segredo não vão no corpo 5. GovBrAuthService::authenticate lê o CPF do sub (11 dígitos). Outro formato lança GovBrAuthException. O nível vem de reliability_info.level (bronze, silver → prata, gold → ouro); ausência vira bronze. O mínimo é security.govbr.minimum_level (padrão bronze). Abaixo do mínimo, AuditService::logBlocked registra o bloqueio (CPF mascarado) e a mensagem orienta a elevar o nível. Nenhuma sessão é criada 6. CPF já cadastrado: conta inativa grava access_logs inativada no canal portal e responde "Sua conta está inativa. Procure o administrador do sistema." Conta ativa atualiza ou cria gov_br_accounts (nível,

ids de confiabilidade, linked_at na primeira vez, last_authenticated_at) e segue. O e-mail não é usado para achar a conta 7. CPF novo: exige e-mail presente e email_verified verdadeiro no provedor; senão, orienta a verificar o e-mail no gov.br ou criar conta com e-mail e senha. Se o e-mail já existe em outra conta, recusa sem vincular. Nome vazio recusa. No sucesso, cria usuário com nome, e-mail, CPF e senha aleatória, markEmailAsVerified(), papel PerfilCidadao::nome(), registro em gov_br_accounts e atividade usuarios / cadastro-govbr 8. Auth::login, regeneração de sessão e atividade acessos / login-govbr com o nível. O destino é o LoginResponse do Fortify: URL pretendida em /gestao é descartada; o restante vai ao painel do portal 9. Falhas de GovBrAuthException são logadas com o motivo técnico; a tela recebe só userMessage Não evidenciado no código: Não há vínculo de conta pelo e-mail quando o CPF não confere. Não há elevação automática de nível. Não há single logout no GOV.BR. O credenciamento no ambiente real do Login Único não está neste código: sem client id e segredo configurados, loginAvailable() permanece falso.

SUMÁRIO

ÉPICO: EP01 — Identidade, Acesso e Segurança

HISTÓRIA DE USUÁRIO: Autenticar com GOV.BR

PRÉ-REQUISITOS

DEPENDÊNCIAS

INTERFACE DE USUÁRIO

TELA 1 - Autenticar com GOV.BR

COMPORTAMENTO ESPERADO TELA 1

APROVAÇÃO DO REQUISITO

ÉPICO: EP01 — Identidade, Acesso e Segurança

Como a SEDUR **quero** autenticar com gov.br**, de modo que** O cidadão entra no portal pelo Login Único. A identidade é o CPF do sub. Conta existente é vinculada; conta nova é criada de verdade. Com o interruptor desligado ou sem credenciais, as rotas recusam e avisam, sem simular sessão.

HISTÓRIA DE USUÁRIO: Autenticar com GOV.BR

Como cidadão com conta GOV.BR **quero** entrar no portal pelo Login Único**, de modo que** usar o Viabiliza sem depender só de CPF e senha local.

PRÉ-REQUISITOS

• Visitante. Rotas públicas com middleware guest: GET /portal/login/govbr (portal.govbr.redirect) e GET /portal/login/govbr/callback (portal.govbr.callback)

• Não há permissão Spatie. O botão na tela de login do Fortify só é montado quando GovBr::loginAvailable() é verdadeiro (canLoginWithGovBr). Não há item de menu

• Depois da sessão, valem as mesmas portas do portal (verified e lgpd.accepted). Conta nova marca o e-mail como verificado e ainda passa pelo termo, se houver termo vigente

• Não há Form Request. As recusas são as de GovBrAuthService e as mensagens de GovBrLoginController::failed. O sub precisa ter 11 dígitos depois de remover não dígitos

DEPENDÊNCIAS

Passadas

• Nenhuma além do que o código desta história já exige

Futuras

• Nenhuma

INTERFACE DE USUÁRIO

TELA 1 - Autenticar com GOV.BR

Caminho no menu: Conforme a permissão e a rota descritas nos pré-requisitos

[INSERIR PRINT DA TELA: Autenticar com GOV.BR]

COMPORTAMENTO ESPERADO TELA 1

Cenário 1: Comportamento evidenciado no código

Dado que o código desta história está como descrito na visão geral

Quando entrar no portal pelo Login Único,

Então O cidadão entra no portal pelo Login Único. A identidade é o CPF do sub. Conta existente é vinculada; conta nova é criada de verdade. Com o interruptor desligado ou sem credenciais, as rotas recusam e avisam, sem simular sessão

APROVAÇÃO DO REQUISITO

A Sudoeste Informática esclarece que o desenvolvimento das funcionalidades descritas neste documento foi realizado de acordo com os requisitos e especificações fornecidos pelo cliente. Nossa equipe seguiu rigorosamente as instruções recebidas, garantindo que o sistema esteja alinhado com o que foi solicitado.

Para evitar possíveis retrabalhos ou ajustes futuros, sugerimos que o cliente revise atentamente os requisitos apresentados, verificando se eles atendem plenamente às suas necessidades e expectativas, bem como se estão em conformidade com eventuais normas aplicáveis ao seu negócio.

Reafirmamos nosso compromisso de entregar um software de qualidade que agregue valor às operações do cliente, e a validação cuidadosa dos requisitos é um passo importante para garantir o sucesso do projeto.

APROVAÇÃO DO REQUISITO			
DATA	**SETOR**	**NOME**	**ASSINATURA**